

Azure Resource Inventory — APIM Security Demo

This document lists **every Azure resource** created for this demo with its specifications, purpose, and configuration. Use this as a reference to reproduce the setup from scratch.

Subscription & Tenant

Property	Value
Subscription Name	ME-MngEnvMCAP557563-sautalwar-1
Subscription ID	08608efd-deb6-42fa-8c1b-3bb2919b41cc
Tenant ID	beb3fb80-9b3e-4ed0-b9eb-bf9ed2c578e5
Tenant Admin	admin@mngenvmcap557563.onmicrosoft.com
Region	East US

Resource Group

Property	Value
Name	rg-apim-security-demo
Location	eastus
Purpose	Contains all resources for the APIM security demo

Resources Created

1. Azure Container Apps Environment

Property	Value
Name	apim-demo-environment
Type	Microsoft.App/managedEnvironments
Location	East US
Purpose	Hosts the backend API container
Log Analytics	Auto-generated workspace workspace-rgapimsecuritydemo9Qsa

2. Backend API — Container App

Property	Value
Name	products-api-backend
Type	Microsoft.App/containerApps

FQDN	products-api-backend.ambitiousrock-3b12f8ac.eastus.azurecontainerapps.io
URL	https://products-api-backend.ambitiousrock-3b12f8ac.eastus.azurecontainerapps.io
Image	ca9da16795a5acr.azurecr.io/products-api-backend
Runtime	Node.js 20 (Alpine)
Port	3000
Ingress	External (public HTTPS)
Min Replicas	1
Max Replicas	3
Purpose	Sample CRUD API (Products) — the backend APIM protects

Endpoints:

Method	Path	Description
GET	/health	Health check
GET	/api/products	List all products
GET	/api/products/{id}	Get single product
POST	/api/products	Create product
PUT	/api/products/{id}	Update product
DELETE	/api/products/{id}	Delete product

3. Azure Container Registry (ACR)

Property	Value
Name	ca9da16795a5acr
Type	Microsoft.ContainerRegistry/registries
SKU	Basic
Admin Enabled	Yes
Purpose	Stores Docker image for the backend API container

4. Log Analytics Workspace

Property	Value
Name	workspace-rgapimsecuritydemo9Qsa
Type	Microsoft.OperationalInsights/workspaces
Purpose	Container Apps logging and diagnostics

5. Azure API Management (APIM)

Property	Value
Name	apim-security-demo-dev-exx1cmfwvdwzi
Type	Microsoft.ApiManagement/service
SKU	Developer (1 unit)
Gateway URL	https://apim-security-demo-dev-exx1cmfwvdwzi.azure-api.net
Developer Portal	https://apim-security-demo-dev-exx1cmfwvdwzi.developer.azure-api.net
Managed Identity	System-assigned (enabled)
TLS Minimum	1.2
Weak Ciphers	Disabled (TripleDES, SSL3.0, TLS 1.0/1.1)
Purpose	API Gateway — enforces security policies on all API traffic

APIM APIs Deployed:

API	Path	Backend
Products API	/products	products-api-backend Container App

APIM Policy Layers:

Level	File	What It Does
Global	policies/global-policy.xml	Rate limiting (60/min per IP), security headers, correlation IDs
API (Products)	policies/api-level-policy.xml	JWT auth (Azure AD), subscription rate limit (100/min), CORS (specific origins only)
Operation (DELETE)	policies/operation-level-policy.xml	Admin role required, ID format validation, extra rate limit (10/min), audit logging

APIM Named Values:

Name	Value	Purpose
tenant-id	beb3fb80-9b3e-4ed0-b9eb-bf9ed2c578e5	Used in JWT validation policies
api-audience	960c03f6-bc63-42de-bc2b-ae86ee5358d6	Used in JWT audience validation

Policy Fragments (Reusable):

Fragment	Purpose
jwt-validation	Azure AD OAuth 2.0 JWT token validation
rate-limiting	Per-subscription throttling + daily quotas

cors-secure	Restrictive CORS (no wildcards)
ip-filtering	IP allowlist/denylist
response-sanitization	Strip server headers, add security headers
request-validation	Content-type enforcement, size limit, SQLi/XSS detection

6. Application Insights

Property	Value
Name	apim-security-demo-dev-exxlcmfvwdwzi-insights
Type	Microsoft.Insights/components
Retention	90 days
Purpose	APM for APIM — request/response logging, error tracking, performance

7. Azure AD App Registration

Property	Value
Display Name	APIM Security Demo API
Application (Client) ID	960c03f6-bc63-42de-bc2b-ae86ee5358d6
Object ID	901efe79-835b-4d35-a49a-acbe368f65a2
Sign-in Audience	Azure AD (single tenant)
Purpose	JWT token issuer for API authentication via APIM

GitHub Repository

Property	Value
Repository	sautalwar/how_APIM_works
URL	https://github.com/sautalwar/how_APIM_works
Visibility	Public
Branch	master

GitHub Automation:

File	Purpose
.github/workflows/apim-security-scan.yml	CI: Scans policy XML on every PR
.github/workflows/deploy-apim.yml	CD: Deploys Bicep to Azure on merge
.github/copilot/agent-ic-security-review.md	AI: Copilot reviews policy changes for OWASP violations

How to Reproduce from Scratch

Prerequisites

- Azure CLI v2.77+ with Bicep
- GitHub CLI (gh)
- Python 3.12+ (for scanner)
- Node.js 20+ (for local API testing)

Step 1: Clone and Setup

```
git clone https://github.com/sautalwar/how_APIM_works.git
cd how_APIM_works
```

Step 2: Azure Login

```
az login
az account set --subscription "<YOUR-SUBSCRIPTION-ID>"
```

Step 3: Create Resource Group

```
az group create --name rg-apim-security-demo --location eastus
```

Step 4: Create Azure AD App Registration

```
az ad app create --display-name "APIM Security Demo API" --sign-in-audience AzureADMyOrg
# Note the appId output – this is your API_AUDIENCE
```

Step 5: Deploy Backend API

```
# Create Container Apps environment
az containerapp env create \
  --name apim-demo-environment \
  --resource-group rg-apim-security-demo \
  --location eastus

# Deploy backend (builds from Dockerfile)
az containerapp up \
  --name products-api-backend \
  --resource-group rg-apim-security-demo \
  --environment apim-demo-environment \
  --source ./sample-api \
  --ingress external \
  --target-port 3000
```

Step 6: Update Bicep Parameters

Edit `infra/parameters/dev.bicepparam` with your values:

- `tenantId` — from `az account show`
- `apiAudience` — from Step 4
- `backendUrl` — from Step 5 output
- `publisherEmail` — your email

Step 7: Deploy APIM

```
az deployment group create \  
  --name apim-security-demo-deploy \  
  --resource-group rg-apim-security-demo \  
  --template-file infra/main.bicep \  
  --parameters infra/parameters/dev.bicepparam  
# 🕒 Takes 20-40 minutes for Developer tier
```

Step 8: Test Through APIM

```
# Get APIM gateway URL  
GATEWAY=$(az deployment group show \  
  --name apim-security-demo-deploy \  
  --resource-group rg-apim-security-demo \  
  --query 'properties.outputs.apimGatewayUrl.value' -o tsv)  
  
# Test (should return 401 – auth required!)  
curl -s "$GATEWAY/products/api/products"
```

Step 9: Run Security Scanner

```
cd security-scanner  
pip install -r requirements.txt  
python scanner.py ../policies/ --format text
```

Step 10: Configure GitHub Secrets

In your repo Settings → Secrets and variables → Actions:

- `AZURE_CLIENT_ID` — Service principal client ID
- `AZURE_TENANT_ID` — Your tenant ID
- `AZURE_SUBSCRIPTION_ID` — Your subscription ID

Cost Estimate

Resource	SKU	Estimated Monthly Cost
Container Apps (1 replica)	Consumption	~\$5-15

Container Registry	Basic	~\$5
APIM	Developer	~\$50
Application Insights	Pay-as-you-go	~\$2-5
Log Analytics	Pay-as-you-go	~\$2-5
Total		~\$65-80/month

⚠️ **To avoid charges:** Delete the resource group when done:

```
az group delete --name rg-apim-security-demo --yes --no-wait
```